CYS 335: ACCESS CONTROL AND INTRUSION DETECTION

LESSON 1

THE STATE OF THREATS AGAINST COMPUTER AND NETWORKED SYSTEMS

- Modern computer and networked systems operate in a highly hostile environment.
- Organizations today rely on interconnected networks, cloud services, mobile devices, and remote access technologies, which significantly expand the attack surface.
- The attack surface is the total number of possible entry points an attacker can exploit.

THE STATE OF THREATS AGAINST COMPUTER AND NETWORKED SYSTEMS…

- Security is no longer just about preventing access but must also focus on detecting and responding to malicious activities that inevitably bypass preventive controls.
- This "assume breach" mentality has become essential in modern cybersecurity.

Modern Threat Environment

- Modern computer systems are constantly exposed to threats due to:
  - Increased internet connectivity
  - Cloud computing
  - Mobile devices and remote access
  - Internet of Things (IoT)
- Attackers no longer need physical access. A single vulnerable service exposed online can be exploited from anywhere in the world.
- Security threats evolve faster than traditional security controls.

Modern Threat Environment

- Evolution of Cyber Threats
- Why Traditional Perimeter Security Fails
- Attack Surface Expansion (Cloud, Mobile, IoT)
- Risk Exposure in Interconnected Systems

The Evolution of Cyber Threats: A Historical Perspective

- **1980s–1990s: The Era of Experimentation**
  - **Characteristics:** Simple viruses and worms, often created for curiosity or fame
  - **Examples:** Morris Worm (1988), Michelangelo virus
  - **Key Limitation:** Limited network connectivity contained spread
  - **Motivation:** Mostly non-malicious, experimental

Evolution of Cyber Threats

- **2000s: The Rise of Financial Motivation**
  - **Characteristics:** Mass malware outbreaks, email-based attacks becoming mainstream
  - **Examples:** ILOVEYOU worm, Code Red, SQL Slammer
  - **Key Development:** Botnets emerge for spam and DDoS attacks
  - **Motivation:** Financial gain through spam, adware, and early ransomware

Evolution of Cyber Threats

- **2010s–Present: The Age of Sophistication**
  - **Characteristics:** Advanced, persistent, and often state-sponsored attacks
  - **Examples:** Stuxnet, WannaCry, SolarWinds supply chain attack
  - **Key Developments:**
    - **Advanced Persistent Threats (APTs):** Long-term, targeted attacks
    - **Ransomware-as-a-Service (RaaS):** Criminal business models
    - **Supply Chain Attacks:** Compromising trusted vendors
    - **Zero-Day Exploits:** Unknown vulnerabilities weaponized
    - **AI-Assisted Attacks:** Automated targeting and evasion

Evolution of Cyber Threats

- The Critical Shift: Attackers have transformed from individual hobbyists to organized, well-funded criminal enterprises and nation-state groups with sophisticated tools and persistent objectives.

Why the Traditional "Castle-and-Moat" Security Model Fails

- Because it assumes threats only come from outside, protecting the perimeter while leaving the internal network vulnerable to lateral movement, insider threats, and compromised credentials.

Why the Traditional "Castle-and-Moat" Security Model Fails

- **The Traditional Assumptions (Now Obsolete):**
  - A clear, trusted **internal network** exists
  - A well-defined, untrusted **external network** surrounds it
  - All attacks originate **from outside** the perimeter
  - If we keep attackers **out**, we're secure

Why "Castle-and-Moat" Security Model Fails Today

1. **Insider Threats Exist**
   - Malicious employees with legitimate access
   - Accidental data exposure by careless users
   - Compromised employee credentials
2. **Perimeter is Blurred or Non-Existent**
   - Cloud services extend beyond corporate network
   - Mobile devices connect from anywhere
   - Remote work removes the concept of "inside"
   - Third-party vendors have network access

Why "Castle-and-Moat" Security Model Fails Today

3. **Encryption Hides Malicious Activity**
   - While HTTPS protects legitimate traffic, it also hides:
     - Malware command-and-control communications
     - Data exfiltration
     - Attack reconnaissance

4. **Attackers Use Legitimate Channels**
   - Phishing steals valid credentials
   - Attackers use approved VPN and remote access tools
   - Malware communicates through allowed ports/protocols

Real-World Examples of Perimeter Failure:

- **Example 1:**
  - A firewall allows all HTTPS traffic (port 443). Malware establishes an encrypted channel to its command server through this allowed port.
- **Example 2:**
  - An employee's VPN credentials are stolen via phishing. The attacker now has "legitimate" full network access.

Real-World Examples of Perimeter Failure:

- **Example 3:** A cloud storage bucket is misconfigured to be publicly accessible, bypassing all network perimeter controls.

- Perimeter security alone cannot detect malicious behavior occurring inside the network.
- Once an attacker breaches the perimeter, traditional defenses often become blind to their activities.

ATTACK SURFACE EXPANSION: NEW FRONTIERS OF VULNERABILITY

- Understanding Attack Surface: The sum of all points where an unauthorized user can try to enter or extract data from your environment.

1. Cloud Computing - The Shared Responsibility Challenge

Traditional Model	Cloud Model
We control everything	Shared responsibility
Physical security ours	Provider handles physical
Network security ours	We configure virtual networks
OS patching ours	We patch guest OS (IaaS)
Application security ours	We secure applications

Common Cloud Vulnerabilities

- **Misconfigured Storage:** Publicly accessible S3 buckets, blob storage
- **Insecure APIs:** Cloud service APIs with weak authentication
- **Identity and Access Management (IAM) Issues:** Overly permissive roles
- **Secret Management:** Hard-coded credentials in cloud scripts

2. Mobile Devices - The Borderless Endpoint

- **BYOD (Bring Your Own Device):** Personal devices accessing corporate data
- **App-Based Threats:** Malicious apps, data leakage through permissions
- **Physical Security Risks:** Lost or stolen devices with corporate access
- **Unsecured Networks:** Devices connecting through public WiFi

3. Internet of Things (IoT) - The Security Afterthought

- **Weak Authentication:** Default passwords, no multi-factor authentication
- **Unpatched Firmware:** Manufacturers rarely provide security updates
- **Lack of Encryption:** Data transmitted in clear text
- **Minimal Processing Power:** Cannot support robust security controls

4. Operational Technology (OT) - The Convergence Risk

- Industrial control systems (ICS) now connected to IT networks
- Legacy systems never designed for internet connectivity
- Critical infrastructure with outdated, unpatchable software

Impact of adopting new technology

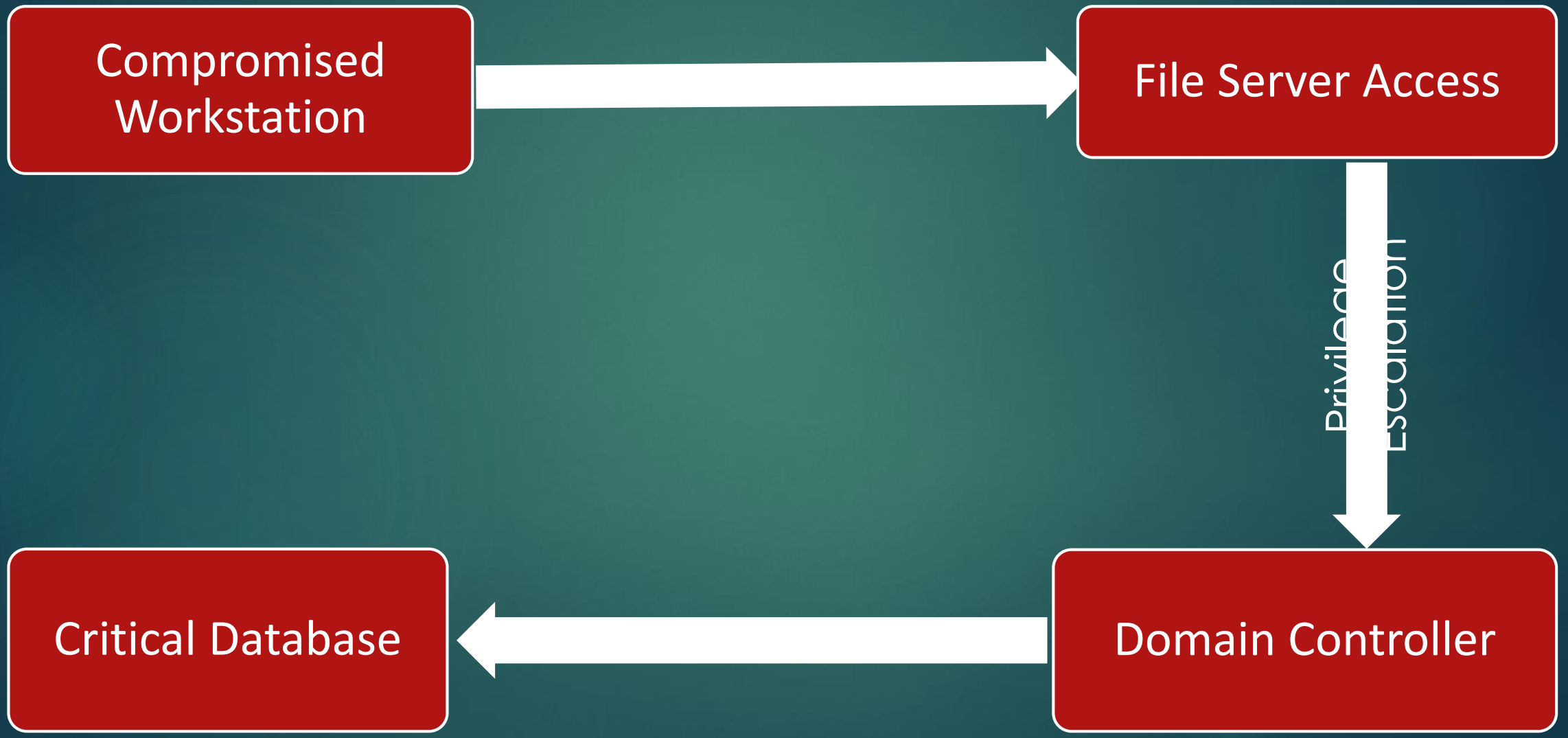
- Each new technology adoption **exponentially increases** vulnerability points, creating a complex web of interconnected risks.

Risk Exposure in Interconnected Systems

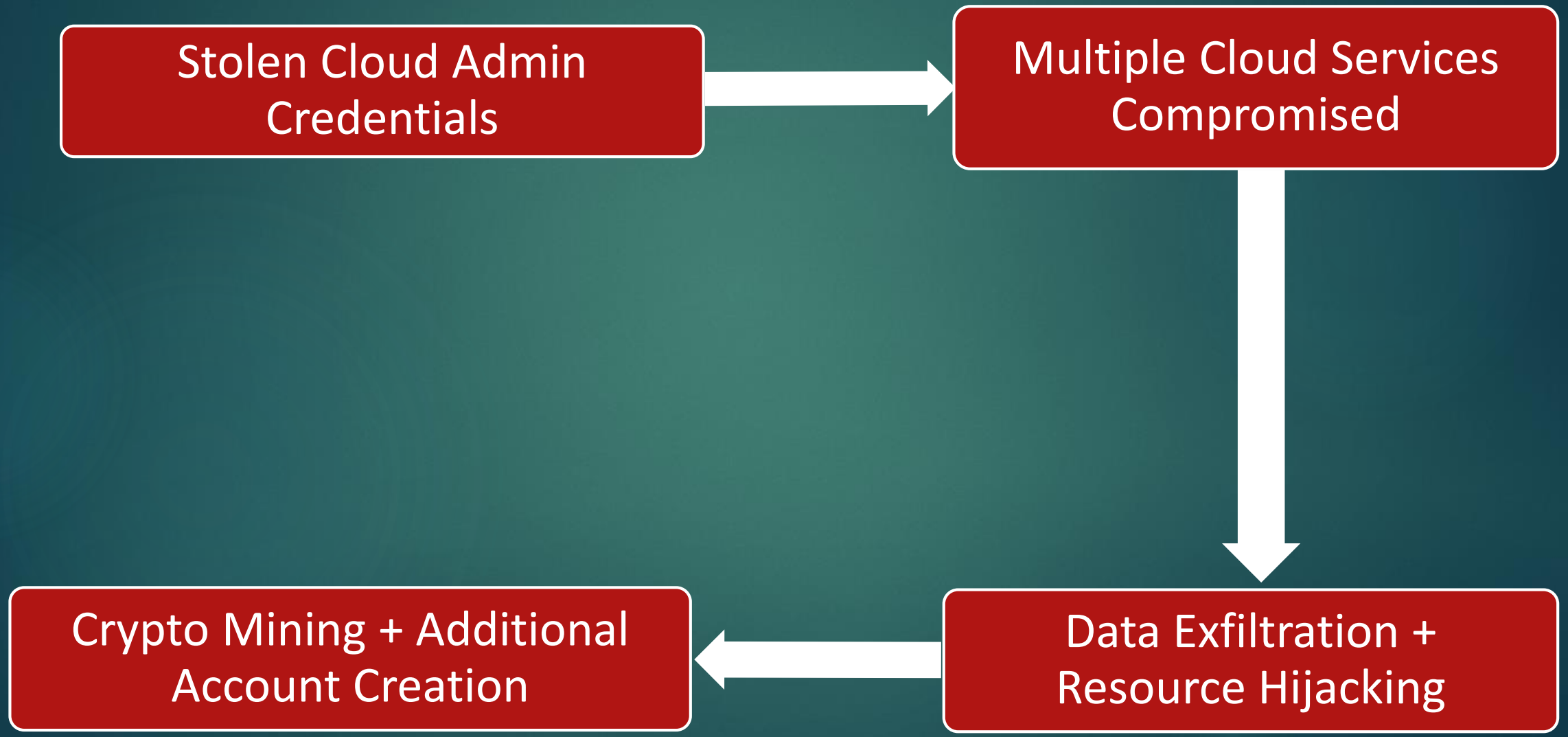
- The Domino Effect in Modern Networks:
- Modern systems are highly interdependent. A compromise in one system can cascade through connected systems like falling dominoes.
  - The "domino effect" in modern networks refers to a cascading failure where a single, often minor, disruption in a hyper-connected digital ecosystem triggers secondary and tertiary failures across APIs, SaaS, CDNs, and critical infrastructure.

Common Attack Paths in Interconnected Systems:

Lateral Movement Sequence:



Cloud Identity Compromise:



Supply Chain Attack Propagation:

